“中国电子杯”第三届高校 ICT 产教融合创新大赛

初赛作品报告

作品题目：智能体驱动的 AI 安全知识情报系统设计与实现（AegisAI）

赛题编号：9

参赛组号：F9-014

摘　要

漏洞公告通常面向上游项目或特定发行分支，安全人员还需结合包身份、部署版本和来源关系，判断公告能否用于具体资产。针对这一问题，本文设计并实现智能体驱动的 AI 安全知识情报系统 AegisAI，连接情报监测、资料富化与资产上下文问答。系统由模型提出调查计划，以任务目录、权限和依赖约束执行；通过 `Evidence`、`Claim` 和 Verification 记录原始依据、待核验事实及支持关系，再由风险分析与 Integration Gate 形成可追溯结果。其设计重点是将必要任务与模型计划分开管理、按公告来源关系评估独立支持，以及在包生态和维护分支内比较资产版本。最终答案保留事实、引用、争议和处置依据，便于分析人员复核。本文给出核心实现、限定场景的运行案例及质量评价，并讨论其作为本地研究与后端演示系统的适用范围。

关键词：AI 安全情报；智能体编排；证据核验；资产上下文；结构化问答

目　录

摘　要.....1

第一章 项目背景与需求分析.....5

1.1 项目背景.....5

1.2 用户需求.....5

1.3 非功能需求与范围.....6

1.4 赛题要求映射.....6

1.5 核心技术与报告安排.....7

第二章 系统总体设计.....8

2.1 设计目标.....8

2.2 总体架构.....8

2.3 核心模块与数据对象.....9

2.4 部署与运行形态.....10

2.5 系统数据流.....10

第三章 智能体架构设计.....11

3.1 设计思路.....11

3.2 智能体协作架构.....11

3.3 Planner 的目标理解与受约束拆解.....12

3.4 Investigation Agent 的调查与信息获取.....12

3.5 Verification Agent 的声明核验.....13

3.6 Security Analysis Agent 的资产风险判断.....13

3.7 Integration Gate 的统一验收.....13

3.8 协作契约与结果交接.....14

第四章 情报监测模块设计.....15

4.1 设计目标.....15

4.2 数据来源覆盖.....15

4.3 采集与标准化流程.....15

4.4 自动化与监测时效.....16

4.5 监测接口与数据交付.....16

第五章 情报富化模块设计.....16
5.1 设计目标.....16
5.2 富化任务与执行边界.....17
5.3 富化维度设计.....17
5.4 富化流程.....18
5.5 富化输出与消费契约.....20
第六章 情报问答模块设计.....20
6.1 设计目标.....20
6.2 输入约束与检索设计.....21
6.3 问答工作流程.....21
6.4 AnswerEnvelope 输出设计.....22
6.5 任务范围与交互边界.....22
6.6 跨文档关联推理的落点.....22
6.7 问答交付与状态语义.....22
第七章 关键技术实现.....22
7.1 技术选型与依据.....22
7.2 Model Gateway.....23
7.3 Agent Runtime 与 Tool Gateway.....24
7.4 Evidence Verification 的关键实现.....25
7.5 核心代码说明.....25
7.6 调查 API 与前后端契约.....28
7.7 幂等、访问隔离与失败处理.....28
7.8 Integration Gate 实现与结果状态.....28
第八章 本项目对照流程与机制比较.....29
8.1 对比说明.....29
8.2 机制对比.....30
第九章 系统实现与功能展示.....30
9.1 展示口径.....30
9.2 情报监测效果.....31
9.3 情报富化效果.....32

9.4 C08 维护分支与指定政策验收.....33
9.5 C09 范围差异与计划恢复.....34
9.6 历史版本案例与独立运行记录.....35
第十章 测试与性能分析.....36
10.1 测试目标.....36
10.2 工程测试.....36
10.3 业务验证与功能验证.....37
10.4 Benchmark 评测体系.....38
10.5 性能与质量指标.....38
10.6 对比实验设计.....39
10.7 测试结果分析.....40
第十一章 创新点总结.....41
11.1 面向 AI 安全场景的多 Agent 自主调查架构.....41
11.2 Evidence 驱动的可信安全分析机制.....41
11.3 资产上下文约束的风险判断闭环.....41
11.4 创新机制与赛题要求对应.....42
第十二章 应用价值与未来展望.....42
12.1 应用场景.....42
12.2 当前限制.....43
12.3 未来工作.....43
参考文献.....44
附录 A 工程证据索引.....44
附录 B 核心源码阅读入口.....47

第一章 项目背景与需求分析

1.1 项目背景

安全运营中的典型问题是：某个已登记的 AI 软件组件是否受到公告中漏洞的影响，应采用哪一维护分支的修复方案，还有哪些部署条件需要确认。漏洞数据库提供标识和评分[4][5]，维护方公告描述影响条件，资产库存记录部署版本。这些资料的名称、版本写法和更新时间往往不同，分析人员需要逐一核对。赛题九提出的监测、富化与问答功能，正是对这一业务过程的系统化支持[9]。

调查中最容易出错的是对象和依据的连接。上游项目与下游发行包可能采用不同版本空间；GitHub、OSV 和博客中的多个链接可能指向同一份公告；漏洞严重性、修复版本发布和资产已应用补丁又分别描述不同事实。因此，AegisAI 在检索之后继续核对包身份、维护分支与证据出处，把公告内容转换为有适用条件的资产判断。

1.2 用户需求

系统面向安全运营、漏洞响应和 AI 软件资产管理人员。用户输入漏洞标识及登记组件后，应能查到公告依据、版本适用范围和可执行的处置建议。对于缺少版本的问题，系统返回需要补充的条件；对于来源之间的差异，系统保留各自的适用范围和待复核事项。表 1 将这些用户需求对应到可检查的输出。

表 1 用户需求与验收方式

需求编号	用户问题	系统应提供的结果	验收方式
R01	最近发现哪些相关漏洞？	来源、发布时间、采集时间及同步状态	采集回执与原文对照
R02	某漏洞有哪些可信资料？	公告、声明、证据与争议项	原文定位及哈希核验
R03	登记的组件版本是否受影响？	精确组件身份、版本观察和范围匹配	调查时的资产快照与边界用例
R04	有 PoC 或补丁吗？	候选、关联依据与验证状态	区分静态关联和实际利用
R05	为什么判定该风险？	事实、风险规则、引用及限制	三角色产物与 Gate Trace
R06	如何进行后续处理？	有依据的建议及需人工确认的条件	修复声明与处置状态核验

1.3 非功能需求与范围

非功能设计重点包括可追溯、受控执行和历史复查。安全事实关联原文与核验产物，任务执行受权限和预算限制，调查读取绑定拥有者，封存答案保留调查时的资产状态。当前业务范围以已接入来源和授权登记库存为基础；互联网资产发现、主动利用及补丁落地属于需要另行授权和实现的能力。

1.4 赛题要求映射

报告按赛题原文的功能、架构、自动化和质量要求组织[9]。表 2 对应九项初赛评分内容，分值合计 100；设计章节说明实现方法，第九、十章给出运行材料和评价结果。提交材料包括 Word 与 PDF 技术报告、操作演示视频和技术讲解材料，各文件应保持同一版本。

表 2 初赛评分项与报告证据映射

评分项	分值	报告位置	设计与实现依据	尚需验证
情报监测功能完整性	15	4.2—4.5、9.2	来源适配、原文保存、标准化和增量同步设计	持续覆盖与时效；标准/政策法规接入待验收
情报富化功能完整性	15	5.2—5.5、9.3—9.5	评分/弱点、范围、候选、资产与 Evidence 领域对象	互联网资产定位、实际利用及各维度质量待验收
情报问答功能完整性	15	6.2—6.7、9.4	受约束调查、版本观察、核验及封存答案契约	完整多轮/攻击链；指定政策要求未完整绑定
监测时效性	5	4.4、10.5	发布时间、采集时间、同步批次和检查点字段	连续发布周期延迟；未证明 24/12/6h 门槛
富化准确率	5	10.4—10.7	声明核验、反证处理和来源独立性规则	字段质量须按官方验收定义另行评价
问答深度与准确率	5	6.6、10.4—10.6	跨文档连接、资产适用性和证据引用设计	更广任务与独立语义评价待补充
智能体架构设计	15	3.3—3.7、7.3—7.4	独立必需任务、DAG 依赖及确定性 Gate	更广任务适应性与消融对照
系统自动化程度	10	图 2、4—7 章	监测/富化入口、任务执行与失败留存机制	连续运行、自愈与 Worker 组合可靠性
文档质量	15	2—11 章、附录 A	架构、流程、核心代码、接口与证据索引	Word/PDF、视频、PPT 的 PDF 须另作赛事材料验收

1.5 核心技术与报告安排

本报告围绕公告如何适用于登记组件展开，重点说明任务完整性、证据支持和资产适用性之间的关系。第七章给出关键代码，随后以运行案例与质量评价检验这些设计。

任务完整性由服务端管理。原始请求确定必要步骤，模型在合法目录内提出路径；输入和依赖明确时，系统补齐缺失节点并复验计划，避免必要资产步骤随生成结果丢失。

证据按声明组织。原文、采集记录、待核验事实及支持材料分别保存，同一公告的转录按共同出处归组。核验能够同时解释支持、冲突和不确定性。

资产判断先确认包名、生态与维护分支，再比较调查时固定的组件版本。最终答案保留事实、引用、争议和处置依据，供分析人员逐项复查。

第二至六章说明架构和模块，第七章给出关键实现，第八章比较机制，第九、十章报告实现效果与测试，第十一、十二章归纳贡献和应用边界。

第二章 系统总体设计

2.1 设计目标

系统要让一次资产影响判断具备完整的解释依据：公告针对什么对象，部署版本是否适用，结论还受哪些条件限制。为此，采集、知识处理、角色执行和最终验收共享可追溯的数据对象，减少分析人员在多个网站、库存记录和答案之间的手工拼接。

2.2 总体架构

系统按数据源、情报采集、知识处理、智能体分析、问答服务和用户展示划分逻辑层，总体架构如图 1 所示。采集与富化产生的知识由调查工具读取，问答服务负责启动、查询和封存调查，界面负责展示进度和结果。各层通过受控接口连接，当前采用本地后端的部署方式。图中实线表示已有的数据与调用关系，虚线标出新版调查工作台尚待验收的接入。

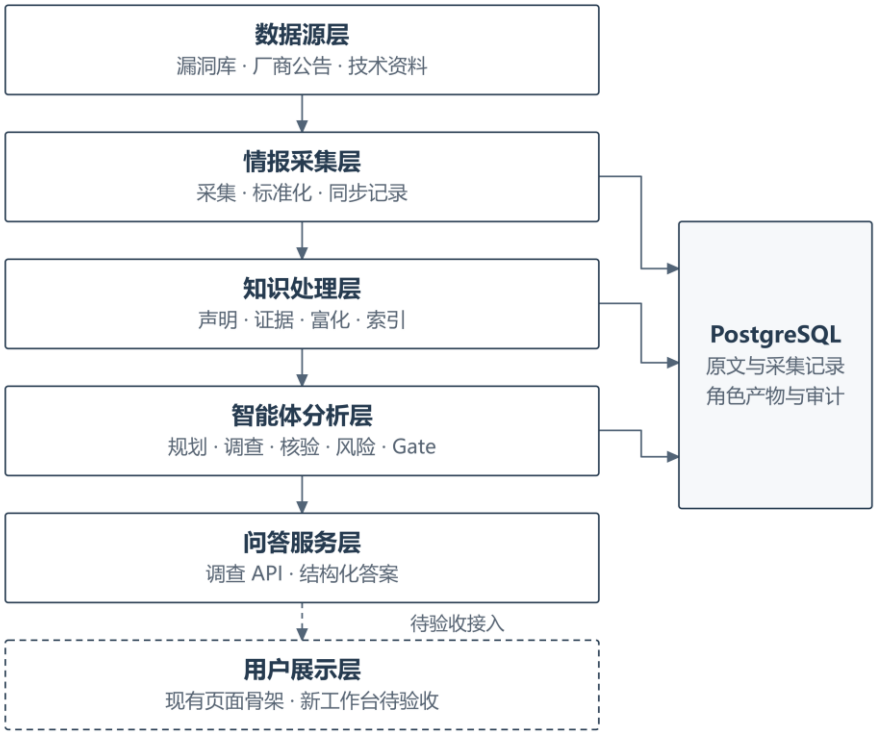


图 1 AegisAI 系统总体架构

正式 HTTP 请求由 Orchestrator 协调执行角色与工具。`get_asset` 和 `inspect_component_version` 从授权库存读取组件信息，数据库保存来源记录、执行产物与封存答案。博客、论文和候选仓库先进入知识层，经过 `Claim` 与 `Evidence` 核验后再作为事实依据。`RawDocument` 保存原始响应或脱敏字段快照，其哈希用于检查内容是否变化；来源真实性另由出处、身份和支持关系判断。

2.3 核心模块与数据对象

情报监测负责源配置、增量采集、原文保存和标准化；情报富化扩展官方说明、评分、利用情报、版本及补丁资料；情报问答组织任务、核验证据并结合资产生成结果。授权资产库存和知识检索为上述模块提供支撑。关联数据目前随业务对象存储，资产信息来自登记记录。表 3 列出主要对象及其约束。

表 3 主要数据对象及关键约束

对象	作用	关键约束
`RawDocument` / `SourceObservation`	保存原始字节及来源采集记录	保存来源、捕获时间、哈希和定位

对象	作用	关键约束
标准化漏洞记录	聚合漏洞身份、别名与产品信息	不丢弃各来源的独立采集记录
`Claim` / `Evidence`	分别表达安全声明与支持材料	同漏洞、同作用域，明确支持或冲突
`VersionObservation`	封存调查时的资产组件版本记录	来自授权资产回执，不猜测缺失版本
`ImpactVersionEvidence`	保存影响范围及修复版本依据	证据级状态不能借用其他证据的确认状态
`AgentRun` / Task / Artifact / `ToolReceipt`	描述执行过程及产物	来源引用、拥有者和审计关联完整
IntegrationResult / Trace	保存统一验收结果和原因	规则固定，历史结果绑定固定上下文
`AnswerEnvelope`	发布可追溯答案	已核验事实、引用、争议、警告分开表达

2.4 部署与运行形态

后端采用 FastAPI 提供类型化 HTTP 接口，使用 SQLAlchemy、Alembic 和 PostgreSQL 管理事务、迁移与持久化。Model Gateway 封装模型调用，使文本生成和向量生成可以分别配置。`Planner` 通过任务目录选择工具，`Runtime` 按依赖执行；部署配置统一管理模型身份、超时、预算及来源策略。

2.5 系统数据流

图 2 展示资料如何进入调查链。原始来源首先保存为快照，漏洞记录、博客和论文再进入富化流程或知识索引。检索返回候选资料，声明核验判断其能支持哪些事实，资产版本记录固定此次比较的对象，问答模块据此组织结果。



图 2 情报采集、富化与问答数据流

三个模块通过来源标识、领域对象和调查产物交接。监测解决资料获取问题，富化建立可核验的事实候选，问答把这些候选放入具体问题和资产范围中解释。每一步均保留处理状态与引用，后续环节可以据此定位缺口。

第三章 智能体架构设计

3.1 设计思路

漏洞调查既需要灵活选择资料，也需要严格判断证据是否适用。AegisAI 因此将规划、调查、核验和风险分析拆分为职责明确的执行角色，以结构化产物交接，并由 Integration Gate 统一验收。模型主要参与受约束规划；证据支持判定、风险规则和答案封存以确定性逻辑执行。这种分工使任务执行与事实采纳能够分别检查。

3.2 智能体协作架构

图 3 展示各角色的协作关系。`Planner` 提出计划，正式校验器检查任务与依赖，调查角色调用工具取得资料，核验和分析角色处理事实与资产适用性。共

享的 Runtime、Tool Gateway 与持久化层负责调度、权限和记录，Integration Gate 汇总跨角色检查结果。

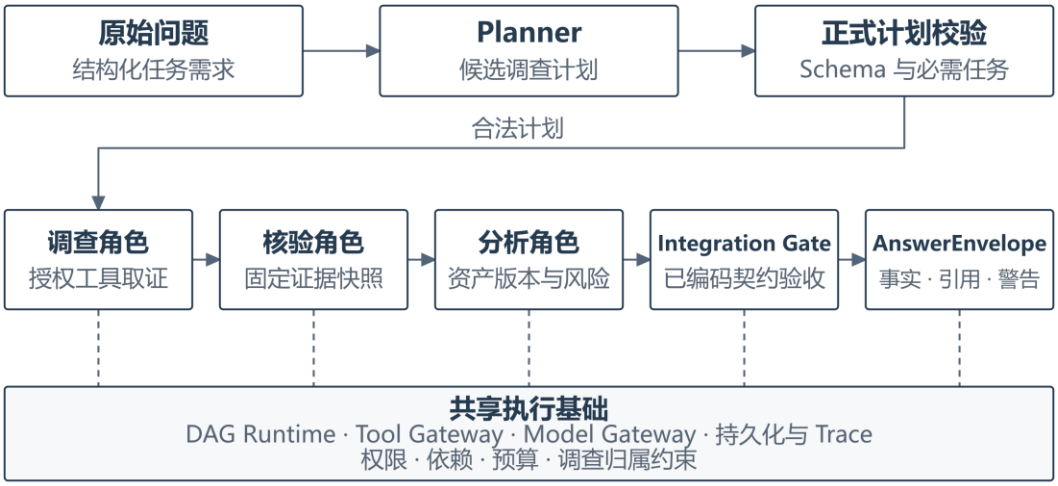


图 3 智能体协作架构

3.3 Planner 的目标理解与受约束拆解

Planner 根据问题提出候选任务，服务端则从原始请求独立提取资产读取、版本检测和证据获取等必要步骤。候选计划先经过 Schema、工具白名单和作用域检查。输入完整、权限允许且依赖可唯一解析时，complete_required_tasks 才补入目录中的合法节点，并重新校验整个计划。缺少必要信息时返回上下文缺口；补齐操作沿用原有重试预算。

3.4 Investigation Agent 的调查与信息获取

调查角色通过已注册工具读取漏洞、声明、证据、资产及语义检索结果，包括 get_vulnerability、search_vulnerabilities、inspect_component_version、get_evidence、get_claims、relation_query、semantic_search 和 get_asset。工具回执形成 InvestigationArtifact，并记录错误与未解决事项。资产版本以授权库存回执为依据，漏洞范围以来源记录为依据；资料缺失时，将缺口交给后续核验和答案处理。

3.5 Verification Agent 的声明核验

核验首先检查对象身份、作用域、原文定位和有效性，再判断证据的支持立场及来源关系。规则排除过期或非当前证据，对适用且匹配的值统计支持；支持与明确反证并存时保留冲突。确认可以来自合格的官方直接证据，也可以来自至少两组独立高质量支持。PoC 的静态关联另需独立显式引用，其结论限于资料关联。

3.6 Security Analysis Agent 的资产风险判断

风险分析先核对包身份和部署版本，再使用已核验的 CVSS、KEV 及 PoC 信息。确认受影响且前置核验通过后，KEV 与外网暴露同时成立时进入 CRITICAL；其他 KEV、高或严重 CVSS、已核验 PoC 关联可进入 HIGH，中、低或信息级严重性按现有规则进入 MEDIUM。处置优先级由 asset-priority-v1 单独计算。用户指定其他政策时，还需明确该政策的身份、版本与执行依据。

3.7 Integration Gate 的统一验收

Integration Gate 通过六类规则检查任务完成、引用一致、事实支持和目标覆盖，按失败、人工复核、重新规划、带警告通过、通过的优先级汇总。其输入为固定调查上下文，执行确定性验收。当前 Objective 依据已编码的结果项检查目标；用户以自然语言指定的政策还需要显式契约，才能核对政策是否真正执行。

表 4 Integration Gate 六类检查

检查类别	核心问题	阻断示例
Completion	必需任务和产物是否完成？	取消、失败、依赖阻塞
Integrity	身份、引用和来源链是否闭合？	核验产物指向另一调查
Evidence	决策事实是否有直接可信支持？	引用存在但不支持声明
Consistency	各角色结论是否一致？	UNKNOWN 被改写为安全

检查类别	核心问题	阻断示例
Objective	是否回答原问题的必要部分？	只给概览而遗漏资产风险
Freshness	来源、核验及库存时间是否合适？	仅有抓取时间，缺少来源发布时间

3.8 协作契约与结果交接

角色之间交接类型化 Artifact、工具回执和调查标识。`Planner` 提供计划，调查角色提供采集结果，Verification 记录支持与争议，风险分析记录资产适用性，Gate 检查整体交付，`AnswerEnvelope` 保存最终响应。表 5 说明各组件在这条链中的责任。

表 5 多角色职责与交接产物

角色/组件	解决的任务	交接产物	赛题设计对应
`Planner`	解析安全需求、保留原目标、生成调查任务	结构化候选、校验/拒绝及尝试记录	自主决策、任务编排和执行边界
Investigation Agent	调查漏洞并获取相关安全资料	工具回执、`InvestigationArtifact` 及缺口	工具调用、信息汇聚
Verification Agent	基于 `Evidence` 检查声明支持性与可信条件	固定快照上的核验状态、支持与冲突	多角色协作、可信分析
Security Analysis Agent	结合授权资产上下文判断版本风险	版本匹配、风险/优先级、处置限制	富化影响评估、资产风险
Integration Gate	检查完整性、证据链、一致性及目标覆盖	PASS、警告、人审、重规划或失败原因	架构合理性、异常处理
`AnswerEnvelope`	对已接受事实及缺口形成可重复读取的答案	引用、争议、未知、风险与警告	问答完整性、可审阅结果

第四章 情报监测模块设计

4.1 设计目标

监测模块将漏洞数据库、博客和论文接入统一采集与知识处理链，记录来源、标题、发布时间、采集时间、批次和入库状态。设计以可增量处理、可恢复检查点和可回查原文为核心，支持后续富化与问答按来源身份读取资料。

4.2 数据来源覆盖

适配层分别处理漏洞数据库的结构化记录、博客 RSS/XML 和论文 Atom 元数据。CVE、NVD 与 OSV 提供漏洞资料[4][5]；博客与论文保留独立的文档身份，缺少漏洞标识、版本或评分时记录为空。表 6 列出不同来源的处理方式。

表 6 数据来源适配与入库对象

来源类别	适配与入库方式	领域输出	适用边界
漏洞数据库	CVE/OSV 及 NVD 结构化记录经标准化入库	漏洞身份、来源采集记录、原文和同步批次	保留各来源采集记录，按检查点进行有界同步
安全博客	Trail of Bits RSS 经安全 XML 解析进入知识库	文章标题、正文定位、时间和检索索引	文章相关性与漏洞关联分别核对
学术论文	arXiv Atom 元数据与摘要进入知识索引	论文身份、摘要、出处和候选关联	语义相似不自动构成论文—漏洞事实关联

4.3 采集与标准化流程

采集流程如图 4 所示。适配器获取原文后，记录同步批次、检查点和内容哈希，再由 Normalizer 转换为领域对象。检查点用于恢复增量进度，哈希用于识别内容变化，来源记录用于回查获取时间和出处。部分抓取或失败批次保留相应状态，剩余条目等待后续调度。标准化保存漏洞别名、产品、范围、评分、时间与参考链接，同时保留各来源的原始采集记录。

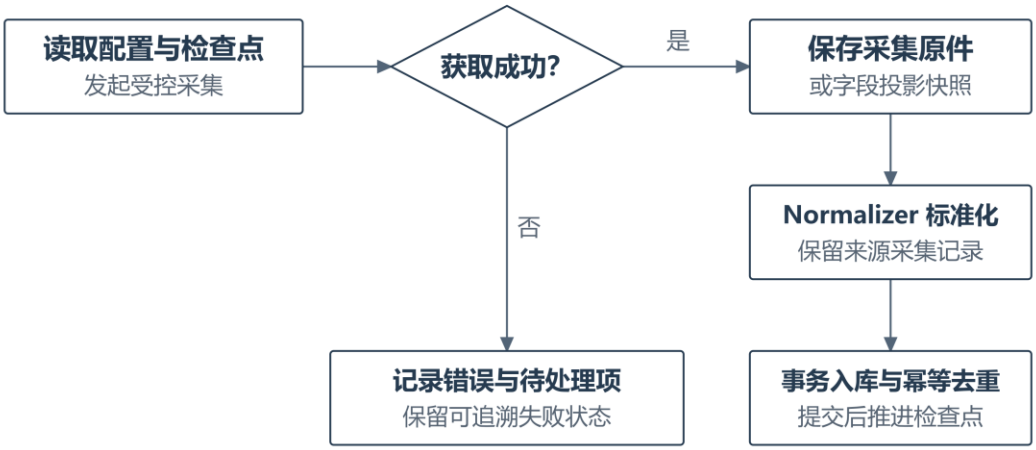


图 4 情报监测与入库流程

4.4 自动化与监测时效

同步与调度入口保留批处理、检查点和失败进度。采集延迟定义为首次成功入库时间减来源发布时间，缺发布时间不补成零延迟。后续须按多个发布周期统计样本量、缺失、失败、积压和 P50/P95，再与赛题 24/12/6 小时档位对照。

4.5 监测接口与数据交付

监测输出由同步批次、RawDocument、SourceObservation 和标准化知识对象组成。RawDocument 保存可复查内容，SourceObservation 记录一次来源采集，标准化对象提供统一访问，检查点记录增量进度。后续核验能够据此还原资料的来源与处理过程。

知识读取接口提供来源、身份、时间和处理状态。调查因此可以区分尚未获取的资料、已获取但未核验的材料，以及已有适用证据支持的事实。

第五章 情报富化模块设计

5.1 设计目标

富化模块将基础漏洞记录扩展为可供判断的资料：评分与弱点解释漏洞属性，版本信息确定影响边界，资产信息固定比较对象，PoC 和补丁资料支持后

续处置分析。每项扩展都关联来源、适用对象和核验状态，为问答提供有依据的候选事实。

5.2 富化任务与执行边界

富化由 EnrichmentService.run 按已登记富化器列表执行。默认顺序为 vendor、epss、kev、poc、patch、version；PoC、补丁与版本任务声明依赖 vendor，选择单项时补入相应依赖。各任务调用 investigate 获取资料或读取已有观察，保存领域对象；随后针对目标漏洞进行冲突检测、逐 `Claim` 核验和知识采纳，并保存状态、`Claim/Evidence/`候选 ID、错误、重试标志及耗时。领域事务异常时回滚相应产物，已采集原文和 FAILED 记录保留。图 5 给出此任务级流程。

问答阶段经 lookup、asset 和 evidence 等任务读取富化知识，再进入调查核验。两类流程共用对象身份与引用契约，但不要求每次问答重新执行全部富化器；生产知识与消费知识的职责因此保持清晰。

5.3 富化维度设计

5.3.1 CVSS 与 CWE

CVSS 记录评分版本、原始向量、分值、来源与时间；风险判断校验向量与分值的一致性，缺失评分保留未知，不按自然语言印象生成新分数[1]。CVSS 描述漏洞严重性，本地资产风险还受组件身份、版本与部署条件约束。CWE 用于保留来源给出的弱点类别，帮助用户理解漏洞成因；它与 CVE 身份及 CVSS 分数含义不同，来源没有给出 CWE 时不由模型随意补号[2]。

5.3.2 影响版本与修复版本

版本富化保留原表达式以及 introduced、fixed、`last_affected`，并按生态、发行包及维护分支比较。OSV 事件 introduced=0 按该生态事件语义表示无明确下界，不是字面版本 0；无法解释的范围保持未知。多个维护分支分别保存和比较，目标修复版本须有对应分支依据；上游范围不自动适用于采用独立回移补丁的下游发行包。

5.3.3 资产关联与影响判断

`get_asset` 与 `inspect_component_version` 的回执记录包名、生态、版本、环境和来源，并封存为本次调查的资产快照。后续分析使用同一快照，以保持比较对象一致。多资产记录按资产和组件关联，暴露面与重要性取自授权库存。

5.3.4 PoC 状态与补丁状态

PoC 搜集通过公开元数据和有限的 README 检查发现候选，分别记录仓库是否存在、是否与漏洞相关以及是否有实际利用验证。表 7 说明报告中的展示语义。补丁资料也分为修复版本声明、补丁可用性和资产应用状态，对应 `FIXED_VERSION`、`PATCH_AVAILABLE` 与 `PATCH_APPLIED`；每一类结论采用各自所需的证据。

表 7 PoC 报告展示语义与判定边界

报告展示语义	判定依据	不能推出的结论
PoC 候选	发现仓库或资料，但支持不足	利用已经成功验证
已确认关联	证据支持与指定漏洞相关	在本地资产可利用
证据不足或限定检索未发现	当前范围缺少合格支持	全网不存在 PoC
利用已验证	需独立可复现的合法验证材料	当前静态抓取不满足该条件

5.3.5 论文、技术资料及 Evidence 关联

论文、文章和仓库保存标题、URL、身份与关联理由，语义相似度用于发现候选。`Evidence` 将候选材料与 `Claim`、原文哈希、定位指针、来源记录及支持立场绑定。建立正式事实关联时，还需核对对象与范围，形成可回查的引用链。

5.4 富化流程

图 5 展示富化任务的选择、逐项执行和结果留存；正常任务返回后执行冲突检测、声明核验与知识采纳，异常任务另存失败结果。图 6 展示多个富化维

度汇入 `Claim/Evidence` 的关系，分别保留身份、范围和来源，再交接核验与分析。

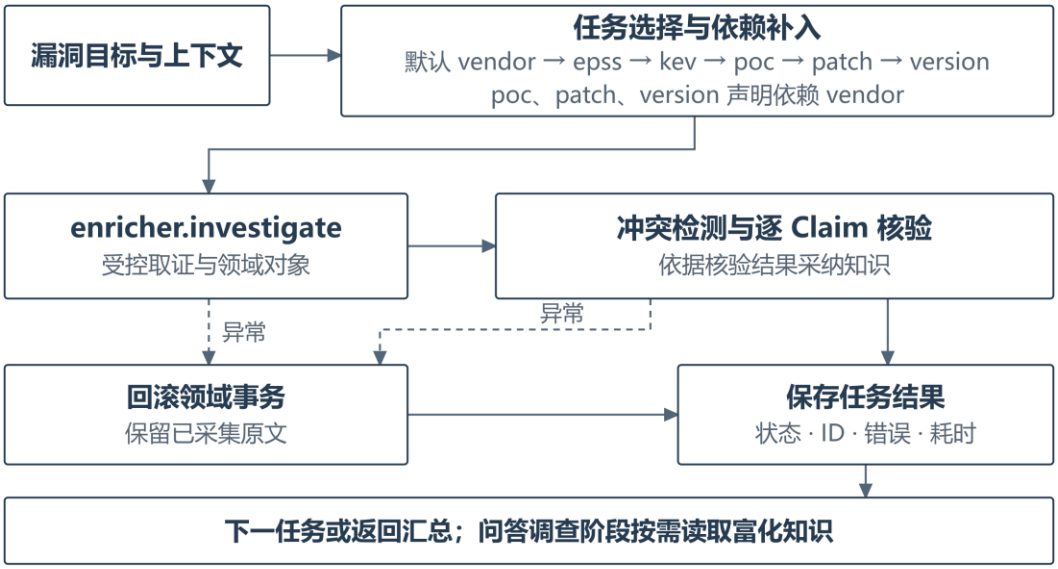


图 5 富化任务执行与结果留存流程

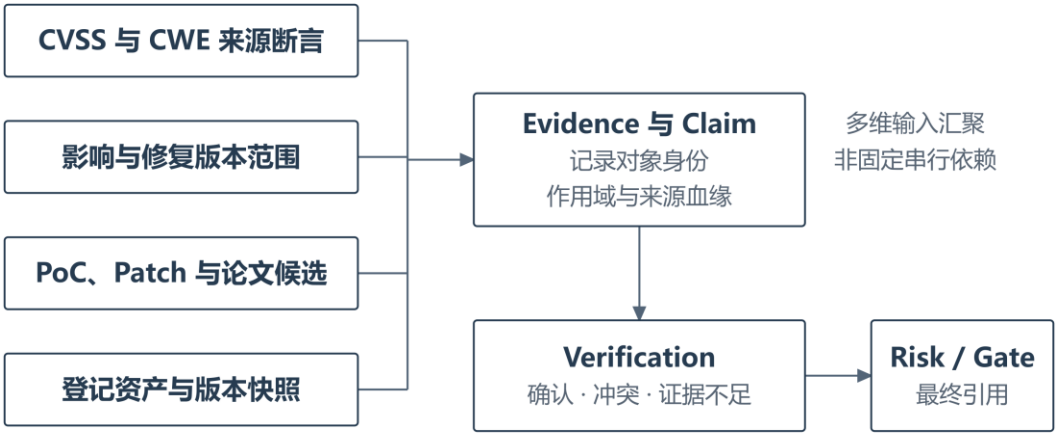


图 6 漏洞情报富化的证据链

5.5 富化输出与消费契约

表 8 汇总各维度的输出。来源评分、版本事件、候选链接和资产快照按各自语义进入知识层；Verification 检查声明级证据，风险分析结合核验结果与固定资产版本作出判断。这样可以分别检查字段完整性、事实支持程度和资产适用性。

表 8 富化维度与输出契约

维度	领域输出与处理能力	消费约束与语义边界
CVSS	保存来源分值、向量；通过结构化事实转换写入 `Claim/Evidence`	转换后进入声明核验流程
CWE	保留来源弱点类别	缺值不由模型补号，不能保证所有记录齐全
影响/修复版本	保留结构化范围，比较精确发行包与登记版本	按精确登记包比较；身份、分支或部署条件未知时保留不确定性
受影响资产	授权库存读取、固定 `VersionObservation` 与影响证据交接	仅登记/演示资产，不是互联网自动扫描
PoC 与 Patch	搜集、展示和关联候选已有实现	分别记录候选、核验关联与资产应用状态
`Evidence` 与影响评估	原文、观察、声明、支持/冲突及规则风险输出	`Claim/Evidence` 保留身份、作用域、立场和原文定位；引用数量不等于支持充分性
论文/技术资料关联	元数据、语义检索与候选关联规则	元数据与相似度用于候选发现，正式关联须有适用证据

第六章 情报问答模块设计

6.1 设计目标

情报问答把用户的安全需求转为调查任务，回答影响范围、修复依据和资产风险，并给出结论对应的资料。模块围绕意图理解、任务规划、跨文档关联、核验及结构化交付展开，服务于赛题对问答完整性、深度和质量的要求。

6.2 输入约束与检索设计

输入包括原始问题及显式提供的漏洞、组件、资产和版本信息。现有任务目录支持单漏洞概览、指定版本和资产影响等调查。规划器按目标选择工具；输入不足时返回所缺条件，范围超出支持能力时保留原目标和范围缺口。

关键词检索处理漏洞标识和包名，语义检索发现跨文档候选。本地 MiniLM 实现支持 384 维向量及有界余弦比较。调查根据需求选择结构化读取、资产快照或语义检索，再对候选的身份、来源和作用域进行核对。检索相关度用于安排调查线索，事实采纳由核验规则决定。

6.3 问答工作流程

图 7 展示自然语言调查的执行过程。系统将问题转为合法计划，依次完成调查、核验、风险分析和门禁检查。通过验收后返回完整或带警告答案；未满足要求时返回对应状态、缺口和原因，供用户补充信息或开展复核。

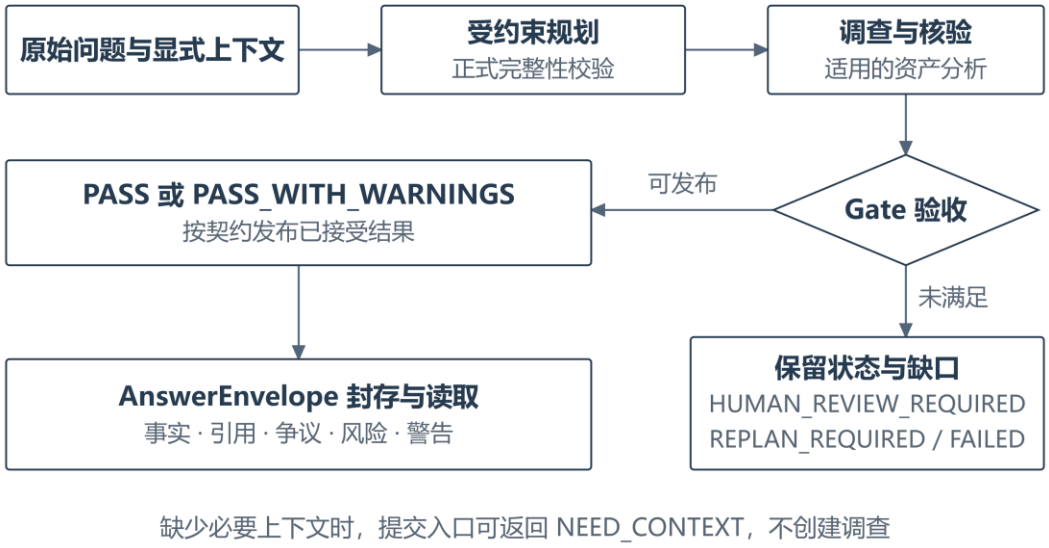


图 7 自然语言调查与答案生成流程

6.4 AnswerEnvelope 输出设计

AnswerComposer 从固定 Gate Context 和角色产物构造 AnswerEnvelope，分别封存已核验事实、引用、资产快照、风险、处置建议、争议及警告。summary 用于传达整体状态，verified_claims 与 citations 承担事实和出处表达，disputed_claims 保留未确认声明。精确修复动作还须引用本次答案已接受的 Claim 与 Evidence，避免建议脱离核验依据。

6.5 任务范围与交互边界

受支持任务包括单漏洞概览、指定组件版本和登记资产影响。输入缺少必要条件时请求补充，资料不足时保留未知或人工复核，超出单目标或工具能力时说明范围限制。计划简化以原始目标为前提，资产判断仍须保留相应步骤。

6.6 跨文档关联推理的落点

跨文档分析依次连接漏洞别名、包生态与包名、公告范围、资产版本及证据引用。别名帮助定位同一漏洞，包身份确定版本空间，维护分支限定修复路径，资产快照固定比较目标。每个连接均保留标识和依据，分析人员可以从最终判断回查中间关系。

6.7 问答交付与状态语义

答案分别记录完成程度和确认程度。缺少输入时返回 NEED_CONTEXT，事实尚不确定时保留 UNKNOWN，仍需人工处理时返回 HUMAN_REVIEW_REQUIRED。带警告完成的答案附上具体限制，失败或证据不足的结果则明确说明停止原因。

第七章 关键技术实现

7.1 技术选型与依据

表 9 汇总实际使用的技术及其选择依据。接口框架负责类型化访问，数据层负责事务与历史记录，任务运行层负责依赖调度，知识层负责检索，模型网关负责统一调用[6][7][8]。

表 9 技术选型与依据

层次	当前实际选型	选择依据	实现要点与边界
HTTP 服务	Python、FastAPI	类型化接口、OpenAPI、明确错误状态	类型化访问与异常状态处理
数据契约	Pydantic v2、JSON Schema	限定字段、枚举和结构化模型结果	字段、类型和枚举检查；事实支持由核验处理
持久化	SQLAlchemy 2、Alembic、PostgreSQL	事务、来源链和历史审计	当前原型运行规模有限
知识检索	FastEmbed/ONNX、本地 MiniLM、关键词检索	可离线运行、语义与精确标识互补	关键词与向量互补，检索配置独立于事实核验
生成调用	Model Gateway、Ollama 兼容接口	调用统一、供应商与业务分离	文本与 Embedding 可分别选择已登记适配器
任务执行	自研 DAG Runtime、Tool Gateway	依赖、权限、预算和可追溯回执	依赖图、权限、预算与产物交接统一管理
前端	原生 JavaScript ESM、History Router、Node 代理	直接对接既有接口、减少阶段依赖	新调查页面尚未验收
工程校验	pytest、Node 测试、TypeScript 契约校验	规则边界、API 与前后端协议验证	模拟测试与真实质量分开

7.2 Model Gateway

Model Gateway 统一文本、结构化生成、Embedding 与健康接口，记录 provider、model、request_id、trace_id、耗时、usage、错误及 is_mock。Planner 响应经 JSON 解析、正式 Schema 和业务完整性校验后才进入 Runtime；字段级错误与被拒计划作为受限数据反馈，修正结果仍须重新校验，尝试耗尽则停止。

文本生成与 Embedding 使用独立适配器，由 `ModelConfig` 管理 Provider、模型、超时和结构化模式。配置来自传入映射或进程环境，不支持的能力在调用前拒绝；配置变化时建立新实例。业务问题只能使用既定模型能力，不能修改进程配置。表 10 展示各调用阶段的处理方式。

表 10 Model Gateway 调用阶段与真实性约束

调用阶段	实现行为	真实性约束
请求进入 Gateway	验证消息、`Schema` 与受限参数	先检查调用结构，再交接事实核验
选择 Provider	使用已配置适配器，分别管理文本/Embedding	以配置中登记的适配器和能力为准
响应处理	JSON 解析、`Schema`/类型校验及受控错误	格式校验与声明核验分层处理
调用记录	保存模型身份、`is_mock`、耗时、usage 和 trace	未知 usage 保留未知；Mock 不进入真实模型质量成绩

7.3 Agent Runtime 与 Tool Gateway

`Runtime` 校验任务图的依赖和环路，执行就绪任务并保存 Artifact 与 `ToolReceipt`。任务以成功、失败、待复核或阻断等状态结束，执行层处理取消、期限与子进程生命周期。工具来自服务端注册目录，Tool Gateway 分别校验读取、写入和外部网络权限。任务数量、深度、调用次数、并发与时限由保护配置控制，表 11 列出状态含义。

表 11 `Runtime` 任务状态与记录

状态类别	当前含义	记录与使用
`CREATED` `PENDING` `READY`	建立、等待依赖或准备执行	TaskTrace 保存状态迁移
RUNNING	工具/角色执行正在进行	保留开始时间、调用及预算
SUCCESS	任务执行产物被执行层接受	可以解锁依赖，不认证安全事实
`FAILED` `WAITING_REVIEW` `BLOCKED`	失败、待复核或依赖/预算阻断	错误、未解决项、Artifact 和 `ToolReceipt` 分别留存

Orchestrator 负责阶段交接，`Runtime` 按合法依赖调度。`task_requirements`(context) 生成必要任务集合，`complete_required_tasks` 根据目录、输入、依赖和权限补齐节点，再复验整个计划。生产任务失败或必要产物缺失时，下游保持阻断，并保留上游原因。

7.4 Evidence Verification 的关键实现

origin(observation) 根据维护方公告引用识别来源关系，再检查对应 GHSA 在官方 advisory-database 中的转录路径。域名、HTTPS 和公告标识匹配后，将转录记录归到同一来源；其他情况保留包仓库线索或原 `lineage_key`。归组依据是可定位的引用关系。

`evaluate_claim` 筛选当前有效证据，比较声明值、作用域和显式立场。支持与反证同时存在时保留冲突；确认入口分别适用于合格的官方直接证据和多组独立高质量支持，PoC 静态关联另受显式引用约束。每次调查生成新的核验快照，已封存的历史答案保持原样。

7.5 核心代码说明

核心实现按任务完整性、声明支持和资产适用性连接。表 12 给出函数位置与输入输出，随后三节展示关键源码及判断逻辑。路径均相对 `backend/app/`，版本信息和文件哈希见附录 A。

表 12 核心代码位置与职责

函数及代码位置	输入与输出	失败或边界
`task_requirements` `agents/investigation/task_invariants.py:31`	PlannerContext → `RequiredTask` 集合	只从正式目标和已给上下文提取
`complete_required_tasks` `agents/investigation/task_invariants.py:52`	原候选、上下文、目录 → 补齐候选	缺输入、依赖、工具或权限时拒绝；随后复验

`schema_feedback`
`agents/investigation/schema_feedback.py:10`
`rejected_context`
`agents/investigation/retry_context.py:8`
	`Schema` 错误及被拒计划 → 字段反馈与重试上下文	路径不丢失；两次耗尽停止

函数及代码位置	输入与输出	失败或边界
origin enrichment/evidence.py:19	SourceObservation → lineage_key	精确 GHSA 转录校验；维护方及原血缘回退
evaluate_claim enrichment/rules.py:40	当前支持/反证 → 核验状态及来源组	冲突保留；PoC 另有独立支持要求
assess_risk agents/analysis/rules.py:186 assess_priority assets/priority.py:5	核验、资产、版本 → 本地风险及 asset-priority-v1	前置条件不满足时保留 UNKNOWN 并阻断确认；非用户命名政策的执行证明
coverage integration/objective.py:28	已编码 Objective 与 Analysis → 结果覆盖	检查已编码 Objective 结果项；命名政策仍需显式身份/版本契约
IntegrationGateEvaluator integration/evaluator.py:33 AnswerComposer orchestration/composer.py:115	固定上下文 → Gate 及封存答案	保留不同状态与引用，不借旧调查 Artifact

7.5.1 必需任务补齐与完整计划复验

生成计划前，task_requirements 将请求中的资产、组件版本和证据需求写入 RequiredTask。complete_required_tasks 仅补入目录内的只读任务，要求权限允许、输入合法且上游生产者唯一。补齐后沿用正式校验链，关键代码如下。节选保留源码逻辑，仅调整长行显示。

```
validator.validate(value)
encoded = json_bytes(value, 65536).decode()
output_model.model_validate_json(encoded, strict=True)
validated = validate_investigation_plan(
    InvestigationPlan.model_validate_json(encoded), context
)
```

这段代码依次检查生成 Schema、严格输出模型和业务计划。最后一层继续核对作用域、权限、依赖、环路及预算，只有返回 ValidatedPlan 的快照可以执行。出现异常时保存拒绝记录，补入的节点仍须由 Runtime 实际执行。

7.5.2 来源归组与声明支持判定

EvidenceService.add 绑定原文、来源记录、声明作用域和定位，并通过 origin 记录共同出处。`evaluate_claim` 随后筛选当前证据中对同一声明值的显式支持，以下代码展示支持项筛选与来源归组。

```
supports = [x for x in current
    if x.get("stance") == "support"
    and canonical_value(kind, x.get("value") or {})
        == canonical_value(kind, value)]
groups = sorted({x.get("lineage") or "unresolved-origin"
    for x in supports if x.get("explicit")
    and x.get("authority") in ("official", "authoritative")})
```

集合以 lineage 归组，`canonical_value` 则按声明类型规范化比较值。规则先检查反证，支持与反证并存时保留冲突。官方直接证据和多组独立支持分别采用对应的确认规则，PoC 关联还需满足独立显式引用条件。

7.5.3 资产适用性与答案发布筛选

`assess_risk` 将资产快照与核验结果写入 `AnalysisContext`，先执行 `match_asset` 和 `match_version`。默认风险为 UNKNOWN、优先级为 `REVIEW_REQUIRED`，前置条件满足后才进入风险规则。`AnswerComposer` 再筛选可以公开的证据，核心 eligible 函数如下。

```
def eligible(e, claim):
    return (e.claim_id == claim.claim_id
        and e.scope_key == claim.scope_key
        and e.integrity_status == "VALID"
        and e.is_current and e.hash and e.raw_document_id
        and e.observation_id and e.source_id
        and e.authority_level in ("official", "authoritative")
        and e.directness == "direct" and e.stance == "support"
        and not e.exclusion_reasons)
```

eligible 要求声明标识和作用域一致，证据完整、当前有效、直接支持且没有排除理由。compose 还检查 grounded，将未确认声明留在 `disputed_claims` 中。精确修复动作仅能引用本次已接受的 `Claim` 和 `Evidence`，因此整体验收与字段发布分别具有可检查的依据。

7.6 调查 API 与前后端契约

表 13 列出正式调查接口。输入通过检查后，提交接口返回 HTTP 202，后续分别读取状态、轨迹、产物、门禁和答案。缺少必需版本时，输入层返回 `NEED_CONTEXT`，并通过 `missing_fields`、`investigation_created` 和 `execution_mode` 说明缺失内容及是否启动调查。

表 13 调查 API 操作

操作	路径	作用
POST	`/api/investigations`	提交调查，接受后返回 202
GET	`/api/investigations/{id}/status`	查询当前阶段与终态
GET	`/api/investigations/{id}/trace`	读取执行轨迹
GET	`/api/investigations/{id}/artifacts`	读取角色产物
GET	`/api/investigations/{id}/integration`	读取 Gate 结果
GET	`/api/investigations/{id}/answer`	读取封存答案
POST	`/api/investigations/{id}/cancel`	申请取消
GET	`/api/investigations/history`	查询授权范围内历史

7.7 幂等、访问隔离与失败处理

幂等键、拥有者和调查标识共同约束重试与读取。同一身份和幂等键对应不同内容时返回冲突；重复读取返回封存答案，新调查使用新幂等键并生成新标识。取消、超时、进程退出和产物缺失均保存受控状态，下游只消费本次调查的合法产物。

7.8 Integration Gate 实现与结果状态

`IntegrationGateEvaluator` 在固定 `IntegrationContext` 上调用六类注册规则，汇总检查与目标覆盖。输入上下文先经过深度复验，非法输入进入受控失败处理。表 14 记录 Gate 的汇总状态，答案完成程度另存 `answer_status`。Objective 的验收范围由已编码契约定义。

表 14 Gate 汇总状态与答案处理原则

汇总状态	对最终结果的含义	答案处理原则
PASS	当前固定输入满足所需检查	可发布本目标范围的已接受结果
PASS_WITH_WARNINGS	必要目标可接受，仍有明确警告或领域未知	保留警告和未知，不改成无条件安全
HUMAN_REVIEW_REQUIRED	存在需人工处理的问题	表明人审需求，不声称人已批准
REPLAN_REQUIRED	目标或必要资料不能满足	返回缺口；不声称已无限自动重规划
FAILED	致命完整性、协议或执行问题	不能发布为正常完整安全结论

Schema 检查生成格式，Evidence 核验判断声明支持，Gate 检查跨产物交接和目标覆盖，AnswerComposer 筛选最终发布字段。各层保存自身状态与原因，使使用者能够区分计划合法、事实可采纳和目标已满足这几种情况。

第八章 本项目对照流程与机制比较

8.1 对比说明

本章从资料获取、任务组织、事实核验和结果留存比较处理机制。人工分析通常需要分别整理出处、资产范围和过程记录；单次模型回答也需要这些外部依据。AegisAI 将相关操作纳入显式对象与执行契约，形成可以逐层检查的调查过程。

8.2 机制对比

表 15 沿同一业务流程比较人工主导方式与当前实现。项目的特点是分别管理原始目标、模型计划、来源关系和资产快照，使灵活的任务选择能够接入确定性的核验流程。

表 15 本项目对照流程与机制比较

维度	传统方式（人工主导对照流程）	AegisAI 当前实现	证据及限制
信息获取	人工查阅多个数据库与资料网站，分别整理	三类来源自动采集、标准化与知识汇聚	原文、来源采集记录与同步进度可回查
任务处理	分析人员决定查询顺序并手动交接	`Planner` 提出受约束计划，`Runtime` 按依赖执行，多个 Agent 交接	自主选择受任务目录、权限及预算约束
结果可信	人工交叉核对；采用单次生成时还需独立查证	`Claim/Evidence` 核验、来源链和确定性 Gate	保留外部来源差异与人工复核入口
风险判断	人工比对组件、版本、部署条件和处置优先级	固定登记资产快照，精确版本比较与规则风险分析	未进行实际企业扫描或所有部署条件验证
结果留存	依赖人工记录调查过程和资料版本	Artifact、`ToolReceipt`、Trace 与 `AnswerEnvelope` 封存	封存调查上下文与引用，不借旧结果替代新调查

第九章 系统实现与功能展示

9.1 展示口径

本章以 2026 年 10 月 18 日冻结版本的两次真实 HTTP 调查展示结果，列出原问题、实际字段、来源和警告。表中的原始摘要与状态保持原样，正文解释结构化字段的业务含义。历史采集投影和早期 vLLM 调查单列于 9.6 节；本章展示范围为后端接口。

9.2 情报监测效果

表 16 概括历史监测批次及知识类型，当前演示沿用冻结来源。博客、论文的 CVE、版本或评分为空时仍保留相应资料身份；它们可供检索，是否支持安全声明由核验另行判断。

表 16 真实来源采集与标准化记录

数据源/资料类别	采集及汇聚记录	标准化与知识对象	当前效果与边界
NVD/漏洞数据库	有界请求获取并入库两条记录；批次 PARTIAL	保留 CVE、来源采集记录、CVSS/CWE 等字段，经标准化投影为漏洞对象	可被情报接口和原调查工具读取；仍有待处理条目
Trail of Bits RSS/博客	两篇安全研究文章入库	XML 来源经安全解析成为博客知识对象，原文、定位与本地 Embedding 保留	可检索；不能强行标为 AI 漏洞或已关联 CVE
arXiv Atom/论文	先前请求失败保留，窄查询重试取得一篇论文	标题、元数据与摘要进入论文知识对象及知识索引	论文可被语义工具读取；不是最新论文完整覆盖

9.3 情报富化效果

表 17 展示 C08、C09 从公告、资产版本到响应字段的连接。两题的声明、证据、原文定位和哈希保存在演示证据索引中，便于检查每项结论使用的材料。

表 17 当前案例的证据与资产连接

连接环节	C08 langchain-core	C09 vLLM	原件定位
原问题与库存	指定 reference-triage 政策；PyPI 1.2.0	0.29.0 是否受影响；PyPI	E14 /request
公告范围	`<0.3.81；>=1.0.0,<1.2.5`	结构`<0.30.0`；正文 ≤0.25.1	维护方 /vulnerabilities 与 /description
资产比较	旧分支 false；1.x 分支 true	按结构上界比较为 true	Analysis 版本 comparisons
修复与引用	建议 1.2.5；对应 `FIXED_VERSION`	建议 0.30.0；正文差异未单独裁定	`/answer/recommended_actions`
核验与警告	版本 `Claim` 已确认；同源警告保留	结构范围 `Claim` 已确认；同源警告保留	`/verified_claims` 与 warnings

C08 两条维护分支同时存在，系统以登记版本选择 1.x 修复建议。C09 引用结构化范围，正文 Affected 小节却给出另一上界；这一差异已进入本报告的结果解释，不改写原 HTTP 状态或原始 `Claim`。

历史资料中还保留 6 个 PoC 和 2 个 Patch 候选，批次与去重口径尚未完整核定，也未完成实际利用或补丁应用确认。论文已进入知识库，但真实论文与漏洞关联尚无可靠命中记录。这些候选材料用于说明资料获取范围。

9.4 C08 维护分支与指定政策验收

原问题：“按 benchmark-reference-triage-v1 评估此演示资产对 CVE-2025-68664 的风险与优先级。”显式资产为 PyPI/langchain-core 1.2.0。表 18 将原始响应与作者解读分开，版本比较和政策验收分别评价。

表 18 C08 原问题与实际 HTTP 结果

原始响应位置	实际返回摘录	结果解释
原问题	按 benchmark-reference-triage-v1 评估此演示资产对 CVE-2025-68664 的风险与优先级	版本 1.2.0，资产来自登记库存
summary	调查结果已通过验收，请同时查看非阻塞警告	key_findings 主要为 Claim ID，须结合结构字段阅读
版本与修复	version_match_status=AFFECTED；fixed_version=1.2.5	与维护方 1.x 分支及适用修复一致
risk_assessment	HIGH / P2；verification_status=CONFIRMED；conclusion_scope=ACCEPTED	如实保留系统输出；指定政策未验证执行
Gate 与答案	integration_status: PASS_WITH_WARNINGS answer_status: COMPLETE_WITH_WARNINGS	这是两个不同状态字段
目标及警告	risk、priority：SATISFIED warnings：SHARED_SOURCE_LINEAGE	未提示指定政策绑定缺口；Objective 验收覆盖不足

公告列出 <0.3.81 和 >=1.0.0,<1.2.5 两个受影响范围[10]。登记版本 1.2.0 命中后者，系统建议升级至对应的 1.2.5，保留了维护分支。风险部分则存在另一项限制：响应将 risk、priority 标为 SATISFIED 并返回 HIGH/P2，但没有记录指定政策的绑定及执行依据，也未给出相应警告。因此，这一案例支持版本分支处理的局部结论，指定政策的目标验收仍需补齐。

9.5 C09 范围差异与计划恢复

原问题：“vllm 版本 0.29.0 是否受 CVE-2026-105752 影响？”表 19 保留同一冻结公告的两处范围。实际比较使用结构字段`<0.30.0`，得出 `in_range`=true；正文 Affected 小节仍记载≤0.25.1 及该版本确认记录[11]。结构字段是现有版本初筛的采纳入口，当前链未对两者差异发布专门警告。

表 19 C09 范围依据和实际执行结果

项目	冻结记录与实际输出	采纳依据与未覆盖项
原问题	vllm 版本 0.29.0 是否受 CVE-2026-105752 影响？	显式 `PyPI/vllm` 0.29.0
结构字段	`/vulnerabilities/0/ vulnerable_version_range: <0.30.0 patched_versions: >=0.30.0`	当前版本初筛读取此字段
公告正文	/description 的 Affected 小节：vLLM≤0.25.1；confirmed on 0.25.1	与结构字段上界不同，不能仅称源码示例
实际比较与建议	0.29.0 < 0.30.0；`in_range`=true；建议 0.30.0	未对 0.29.0 执行利用或上述部署条件验证
计划与 `Runtime`	首次 tasks[0]/tasks[1].`acceptance_criteria` 缺失；第二次复验后执行 lookup 和 asset	原两次尝试；版本观察真实执行
实际状态与警告	Gate: `PASS_WITH_WARNINGS` 答案: `COMPLETE_WITH_WARNINGS` 警告: `SHARED_SOURCE_LINEAGE`	未给公告内部范围差异专门警告；`MEDIUM/P3` 为本地规则输出

0.29.0 命中公告结构化范围，但现有记录不足以裁定其与正文上界的差异。Harmony `/v1/responses`、prefix caching、工具续接、`cache_salt` 和可猜测续接历史等部署前提也未在该资产上验证。执行过程中，首次计划缺少两个 `acceptance_criteria` 字段，第二次修正并复验后进入 `Runtime`，沿用原有两次尝试上限。C08、C09 的采集端壁钟时间分别约 52.50 秒和 46.50 秒，均为顺序调用；调查与引用记录见附录 A。

9.6 历史版本案例与独立运行记录

本节保留早期 API 投影和 vLLM 0.6.5 调查，作为独立历史版本。旧案例涉及 V0 引擎和 PyNcclPipe KV cache transfer 环境，HIGH/P1、修复版本 0.8.5 及 68.656 秒均来自该次运行[3]。

表 20 历史情报 API 字段投影

字段/维度	CVE-2022-45907 投影	CVE-2025-32434 投影	解释
来源/产品	来源含 NVD、OSV；受影响产品含 PyTorch	来源含 NVD；受影响产品为空	不从另一记录借用或补造产品
CVSS	包含 3.1/9.8 来源断言，另有其他来源/版本记录	包含 3.1/9.8 及 4.0/9.3 来源断言	按版本、Provider 和观察区分；不当作独立证据多数表决
CWE	CWE-77、CWE-94	CWE-502	保留来源分类，不由模型补号
影响/修复版本	OSV 范围事件含 introduced=0、fixed=1.13.1；解析成功	受影响版本和修复版本均为空	解析成功与核验成功不同；空值保留
核验层级	范围核验状态为 pending；修复与评分为来源断言	评分及整体状态为来源断言	来源说法尚不能自动进入已确认风险
PoC/文献关联	PoC 候选；关联文档为空	PoC 候选；关联文档为空	候选搜集可展示；有效利用及真实论文关联未证明

表 21 历史 vLLM 完整调查流程

步骤	实际输入与处理	可审阅结果
用户问题	明确漏洞、登记资产、组件及版本范围	原始目标绑定，不允许缩成仅概览
Planner	本地 Qwen2.5 生成计划，服务端校验	第一次 QUERY_SCOPE_MISMATCH 拒绝；第二次 VALIDATED
Investigation Agent	读取漏洞/资料及授权资产，通过工具形成产物	影响范围、来源和固定 VersionObservation 进入交接
Verification Agent	核验固定声明、Evidence 和范围	历史回执记载 5 项 Claim 确认，支持来源可追溯
Security Analysis Agent	比较固定版本与已确认影响范围	AFFECTED；既有规则输出 HIGH/P1，受登记条件限制
Integration Gate	检查六类条件及原始目标覆盖	PASS；不是实际利用已验证
Answer Envelope	从已验收产物构成并封存答案	COMPLETE，引用和限制保留，同一答案重复读取一致

该历史调查采用受影响范围 >=0.6.5,<0.8.5，修复版本 0.8.5，CVSS 3.1/9.8；门禁为 PASS，答案为 COMPLETE。记录与当时的来源和资产快照绑定，供复查该次调查过程。

第十章 测试与性能分析

10.1 测试目标

测试与性能分析分别检查工程契约、真实业务链可运行性及独立标准下的质量，对应监测时效、富化准确率和问答深度与准确率三项性能指标。测试数量是辅助证据，业务事实与性能须由各自的验证材料判断。

10.2 工程测试

工程测试覆盖 Schema、依赖、工具白名单、引用关联、幂等、隔离和异常阻断。Windows 同序组合测试共 99 项，91 项通过、8 项失败；首次异常发生在

CreateProcess，返回 WinError 5，此时 Worker 尚无 PID。独立 Worker 组共 8 项，3 项通过、5 项失败，但未完整取得底层异常码。两组记录分别保留，目前尚不能认定同因。表 25 给出各组范围和原始日志核对方式。

10.3 业务验证与功能验证

业务验证要求原问题、真实来源、工具回执、核验产物、`Risk/Gate` 和答案相互对应。表 22 说明三模块当前证据覆盖；C08 政策验收缺口和 C09 公告内差异说明完整可追踪仍须与实际业务满足度分开核对。

当前演示的两次调查共留存 6 个新 Artifact 和 33 条证据引用，数量仅用于核对交接与引用完整性，不作为独立事实或业务正确率指标。来源血缘修复在最新完整实验中纠正 7 题、涉及 4 个不同 `Claim` 的 22 次重复确认实例；原有版本冲突继续保留。

表 22 三大模块功能验证与判定范围

模块	验证对象	已取得材料	本阶段可支持的结论	仍缺材料
情报监测	数据采集、原文留存、标准化及知识读取	三类来源运行状态、Raw 出处、情报 API 投影、语义检索记录	有限真实批次已入库并可读取；失败与 PARTIAL 保留	连续运行、相关性审核、延迟统计
情报富化	`CVSS/CWE`/版本、候选、`Claim/Evidence` 和资产交接	字段摘录、结构化事实转换、历史 Version Observation 回执	多维字段及状态可追溯；历史限定资产链有效	自动确认质量、PoC 实际利用、企业库存、论文关联命中
情报问答	复杂查询的计划、工具、三角色、Gate 和答案	冻结 `C08/C09` 及旧完整链；缺上下文和冲突真实记录	限定调查可执行；拒绝/警告与证据关联可查	语义与多跳质量、更多查询类型仍需评价

10.4 Benchmark 评测体系

AegisBench 使用 AegisBench-v0.4-human49-20261014 的 49 题，冻结审批状态 49/49 APPROVED；Gold 仅用于评分，没有进入业务上下文。5 个公告簇在开发过程中反复使用，不是独立保留测试集。严格整题要求该题所有原评分字段匹配，字段统计分母 94；风险等级是其中 10 个 risk_level 字段。失败、未知、冲突、需上下文及不支持题均保留原分母。

该完整实验使用本地 Ollama 兼容服务，模型 aegisai-qwen25-planner:latest，digest 以 15aaf3fda3b8 开头，父模型记录为 qwen2.5:7b-instruct-q4_K_M；temperature=0，max_tokens=4096，单次模型超时 60 秒，Planner 最多两次尝试。输入采用 19 份冻结公共来源图重放，Embedding 为 mock-embedding-v1（384 维），不是当次实时刷新。模型完整 digest 及源码、数据库/资产快照由附录 A 定位。

10.5 性能与质量指标

最近完整实验严格整题 17/49（34.69%）、字段 41/94（43.62%），风险等级字段 4/10；C25 历史分别为 16/49、43/94、4/10。风险题严格整题仅 1/10，与风险等级字段 4/10 是不同统计。表 23 由既存结果按原 question_type 离线分组，全部分组相加与原总分一致。

表 23 既存 49 题按题型的自动匹配结果

题型与题数	原有定义及统计对象	实际匹配结果
事实 5 题	整题须该题全部字段匹配	整题 0/5；字段 10/25
版本 17 题	整题须该题全部字段匹配	整题 8/17；字段 8/17
PoC 与补丁 10 题	整题须该题全部字段匹配	整题 5/10；字段 8/15
风险 10 题	整题须该题全部字段匹配	整题 1/10；字段 12/30
多跳 7 题	整题须该题全部字段匹配	整题 3/7；字段 3/7
合计 49 题	49 题、94 字段不排除拒答或失败	整题 17/49；字段 41/94
风险等级字段	仅 risk_level 的 10 个字段	4/10；风险整题为 1/10

10.6 对比实验设计

配对实验沿用冻结的系统输出，并以同模型单次回答作为对照：8 道主要可比题、2 道范围探索题，另 2 道因 PyPI 证据摘录不等同而排除直接胜负。三位真人评审评价相同的 8 道题，独立性记录仍有缺口，第三份历史锁定指纹未能验证；合格的真实事实冲突样本为 0。C08 的分支处理和 C09 的引用存在局部有利证据，C03、C12 保留反例。现有材料尚未建立整体相对优势。表 24 列出后续质量评价口径；RAG-only 和移除 Verification 的消融实验尚无可比结果。

表 24 质量与性能指标的待验收口径

待测维度	项目拟用口径	当前证据与缺口	验收边界	相关位置
持续监测时效	发布至首次有效入库；缺失时间与失败单列	尚无跨周期 P50/P95	对照官方 24/12/6h；一次抓取不替代	4.4 节
富化与基础问答质量	合格人工事实判断/全部应评项；另报可判定覆盖与弃答数	尚无充分独立语义结果	这套分母是拟定口径，非官方已规定算法	10.4—10.6
多跳与证据支持	中间实体、连接边、最终事实分别审查	有局部连接与 8 主要配对题	范围探索不作真实事实冲突验证	6.6 节
无依据确认	人工核对实质断言及支持缺失	同源支持等级纠正已验证	未形成整体幻觉率	7.4 节
响应与吞吐	完整调查/封存读取分组；n 及失败均报	两次顺序壁钟时间；吞吐未测	不计算 P95 或生产 SLA	10.7 节

10.7 测试结果分析

表 25 按版本和测试范围保留工程记录。来源归组修复的 12 项专项测试与相关 88 项覆盖有重叠，应分别理解；两个真实 HTTP 案例另用于检查业务链。Windows 组合测试失败与单项通过的差异仍未解决。

表 25 历史工程测试记录

阶段/套件	历史记录	范围	核对方式
早期后端全量回归	1261 通过，23 警告	当时版本的完整后端	读取原始日志尾部
证据链修订版后端组合	1426 通过，0 失败/跳过	独立空 PostgreSQL；Mock LLM	封存 verification.json 与阶段报告一致
证据链修订版前端	23 通过	已有前端测试	封存记录
证据链修订版接口契约	TypeScript PASS；42 个 HTTP 契约操作	整个工程协议检查	封存记录
评测工具接入阶段	48 项新增测试通过	Runner、数据及状态契约	阶段报告，未重跑
来源独立性修复	专项 12 项通过；相关 88 项覆盖通过	对应冻结版本；组间不相加	附录 A 来源独立性条目的原始日志；本轮编辑未重跑
Windows 同序组合测试	99 项，91 通过、8 失败	首错 `CreateProcess/WinError5`；Worker 无 PID，底层根因未确认	附录 A Worker 条目的同序日志，可能受组合环境影响
独立 Worker 测试组	8 项，3 通过、5 失败	底层异常码未完整取得，未证明与组合首错同因	附录 A Worker 条目的独立组记录，两组原因分别保留

性能记录仅限 n=2 顺序调查：C08 约 52.50 秒，C09 约 46.50 秒，包含模型、执行和轮询，既非缓存查询速度，也非 P95。旧 vLLM 的 68.656 秒属于

9.6 节的另一版本运行，不参与这组统计。B 组 12 次单次模型调用合计约 107 秒、无重试，预算与时点不同，不能据此计算架构速度提升。

与历史冻结基线相比，整题匹配由 16 增至 17，字段匹配由 43 降至 41。任务完整性加固恢复一题，同源归组纠正撤回三个原匹配字段，并恢复另一个候选字段，净减少两项。全部终态为 25 题带警告完成、9 题不完整、8 题待复核、5 题需上下文及 2 题无可用答案。未匹配原因包括 torch 事实题的支持不足与摘要字面差异、GHSA-47fc 版本题的范围冲突、风险题的政策语义差异，以及跨公告题的批量目标范围限制。这些情况应分别判断业务性质。

第十一章 创新点总结

11.1 面向 AI 安全场景的多 Agent 自主调查架构

本项目将正式任务需求提升为独立于生成计划的服务端不变量。模型可自主选择合法调查路径，但任务目录、输入作用域、工具权限、依赖图和预算共同决定其可执行边界；缺失步骤只在条件充分时进行确定性补齐并复验。该设计将生成灵活性与可检查的执行责任结合，针对安全调查中“计划看似完整却省略必要资产步骤”的风险提供明确约束。

11.2 Evidence 驱动的可信安全分析机制

项目将原文可追溯性、声明支持性与来源独立性分开建模：`RawDocument` 保存资料，`Claim` 表达待核验命题，`Evidence` 记录定位、立场和作用域，来源血缘描述共同事实出处。核验结果不仅给出状态，还保留支持、反证与弃判依据，为事实采纳、冲突复核和最终引用提供统一中间层。

11.3 资产上下文约束的风险判断闭环

项目将资产快照与公告范围分别封存，先按包身份、生态与维护分支核对适用性，再对固定版本作范围比较。CVSS 严重性、利用情报、资产风险和处置优先级保持各自语义，精确修复建议关联相应声明与证据。由此形成从外部公告到资产解释的可回查路径，同时保留部署条件和命名政策的适用边界。

11.4 创新机制与赛题要求对应

表 26 将设计贡献对应到业务问题、实现入口和赛题要求。核心贡献是联合约束任务、证据和资产作用域，使每次调查的必要步骤、事实依据及适用对象都能够被检查。

表 26 创新机制与赛题要求对应

设计贡献	解决的具体断点	实现入口与契约	评分对应	能力边界
目标需求独立于计划	生成端可能遗漏必要业务步骤	`task_requirements`、`complete_required_tasks` 及完整性复验	表 2 架构、问答、自动化	仅在正式目录、明确输入及可解析依赖下补齐
血缘与支持等级分离	多个 URL 可能来自同一事实出处	origin、EvidenceService 及 `evaluate_claim`	表 2 富化、质量、架构	归组依赖可追溯关系；不以多数网址证明事实
资产快照与范围分离	上游、下游及维护分支的版本空间不同	`match_asset`、`match_version`、`assess_risk` 及 `AnswerComposer`	表 2 富化、问答、自动化	风险规则不替代任意命名政策和部署前提核验

第十二章 应用价值与未来展望

12.1 应用场景

AegisAI 适用于 AI 软件组件漏洞排查、供应链情报研究和响应辅助。系统将公告范围、登记资产版本、核验引用和处置依据组织为统一结果，帮助分析人员判断结论适用于谁、来自何处以及仍需核实什么。当前适用范围为本地研究与后端演示。

12.2 当前限制

当前限制主要涉及政策语义、知识覆盖、资产处置与运行可靠性，汇总见表 27。系统需要人工复核，尚缺少生产环境下的持续运行验证。历史回退源码和数据库备份与后续增量分别保存，恢复时须核对对应版本。

表 27 当前限制与对结论的影响

事项	当前能力边界	应用与后续验收要求
指定政策与范围解释	Objective 覆盖已编码要求	命名政策身份/版本及公告内范围差异仍需显式采纳依据；相关表现见第九章
语义质量及整体优势	独立质量证据尚不充分	语义正确性需独立评价；配对评审及其记录局限见第十章
监测及知识覆盖	限于已接入来源及有限采集范围	持续时效、标准与政策法规接入、论文关联均须专门验收
资产与实际处置	以授权登记库存为范围	互联网资产定位、实际利用和补丁落地需要独立授权与实证
演示界面与交付	当前面向本地后端演示	GUI、演示材料、冷启动及增量恢复须单独验收
Worker 及连续运行	Windows 组合执行可靠性尚未解决	并发、取消及超时后的连续调查尚未充分验证
来源规则与历史结果	封存答案不可变	旧缓存及其他知识展示入口需分别复核，不能继承新调查的核验结论

12.3 未来工作

后续首先完善指定政策的身份、规则版本与目标验收绑定，并处理公告正文和结构化范围不一致时的采纳说明。质量评价采用按公告簇隔离的样本，并补齐独立评审与锁定记录。工程上优先验证 GUI 操作、冷启动、取消和超时后的连续请求，以及 Worker 组合执行；资产发现、利用验证和补丁落地则在获得授权后单独建设。

参考文献

[1] FIRST. Common vulnerability scoring system version 3.1: Specification document[EB/OL]. (2019-06-01)[2026-10-14]. https://www.first.org/cvss/v3.1/specification-document.

[2] MITRE. Common weakness enumeration: About CWE[EB/OL]. [2026-10-14]. https://cwe.mitre.org/about/index.html.

[3] VLLM PROJECT. Security advisory GHSA-hjq4-87xh-g4fv[EB/OL]. [2026-10-14]. https://github.com/vllm-project/vllm/security/advisories/GHSA-hjq4-87xh-g4fv.

[4] NIST. National vulnerability database[EB/OL]. [2026-10-14]. https://nvd.nist.gov.

[5] OSV. Open source vulnerabilities[EB/OL]. [2026-10-14]. https://osv.dev.

[6] RAMÍREZ S. FastAPI documentation[EB/OL]. [2026-10-19]. https://fastapi.tiangolo.com/.

[7] SQLAlchemy. SQLAlchemy 2.0 documentation[EB/OL]. [2026-10-14]. https://docs.sqlalchemy.org.

[8] PostgreSQL Global Development Group. PostgreSQL documentation[EB/OL]. [2026-10-14]. https://www.postgresql.org/docs/.

[9] 奇安信科技集团股份有限公司. “中国电子杯”第三届高校 ICT 产教融合创新大赛赛题九：智能体驱动的 AI 安全知识情报系统设计与实现[Z]. 2026.

[10] LANGCHAIN AI. LangChain serialization injection vulnerability enables secret extraction in dumps/loads APIs (GHSA-c67j-w6g6-q2cm)[EB/OL]. [2026-10-18]. https://github.com/langchain-ai/langchain/security/advisories/GHSA-c67j-w6g6-q2cm.

[11] VLLM PROJECT. Harmony tool continuations drop cache_salt — restoring a cross-tenant prefix-cache membership oracle (GHSA-935w-9g4m-p28p)[EB/OL]. [2026-10-18]. https://github.com/vllm-project/vllm/security/advisories/GHSA-935w-9g4m-p28p.

附录 A 工程证据索引

表 28 按项目根目录的相对路径列出源码、配置、原始请求及封存产物。工程交付包可依据这些路径定位材料，本附录另保留关键文件指纹和调查标识，用于版本复核。

环境与版本清单：outputs/final-accuracy-validation/environment-freeze.json

数据集：AegisBench-v0.4-human49-20261014

基础提交：88741c7e5ed0d3d684a89ba9bcb67021850c8314

源码定位同时包含该清单中的未提交文件及其哈希。

模型摘要指纹（digest）：

15aaf3fda3b8e9bb6724e5e9911eec3b9cbdb6bd967646b6bf49ee9846b7ec16

环境清单 SHA256：

0d331edf4002c8dadeebf5547fcad78c1f9fc6e9edcef1dea55fbb4babdbc9a2

演示记录：outputs/final-live-demo/live-C08.json、live-C09.json

C08 调查：78eabee2-b88b-4b39-b39d-7536f4350b41

C09 调查：37a0d8a1-3bfd-49f8-b841-21009fed28b8

live-evidence-reference-matrix.csv 记录声明标识、证据标识、原文定位、哈希及 Run/Task 关联。原始结构字段与公告正文分别保留，可以从结果回查来源。

演示记录中的 actual-wire 和执行冻结清单保存运行时间、实际模型请求与原始响应，时间按原件 UTC 解释。各次运行按自身版本与调查标识单独定位。

历史回退版本包含源码 ZIP 和数据库 dump；来源归组增量另以补丁和前后哈希记录，恢复候选版本时需同时应用对应增量。

文件：outputs/final-live-demo/live-C08.json

SHA256：7f9035c93f545ae8b1ef697cd6cf049d58b0353c8bffc6a6809fe83b18bd0ed1

文件：outputs/final-live-demo/live-C09.json

SHA256：0a9a5c182e8e77a832d8656f55b76f61487d9b5cbc8d51459670a97c21d04207

文件：outputs/final-accuracy-validation/49-question-results.json

SHA256：600d610e9c9ddcca2062d8e1f1624ec79ab5a26a1ddd6e291ed97b4f448fcc69

表 28 工程证据索引

编号	材料	支持内容
E01	requirements/sources/competition_problem_9.pdf（第 2–3 页）	初赛提交要求、核心代码说明及评分标准
E02	backend/app/、backend/requirements.txt、frontend/package.json、CURRENT_STATUS.md	实际技术栈、角色、Runtime、API 和前端边界
E03	docs/INTEGRATION_GATE_IMPLEMENTATION.md、backend/app/integration/	六类规则、状态优先级、来源链与边界
E04	PHASE_12D3_RESULT.md、docs/phase12d3/verification.json	封存观察、证据修复与历史工程验证原件

编号	材料	支持内容
E05	docs/phase12d3/real-http-post-review.json、demo/phase12d3/README.md	历史真实模型及 HTTP 执行记录
E06	PHASE_13B_RESULT.md、evaluation/reports/phase13b-final-20261011/report.json	早期评测工程与配置材料，后续正式结果见 E12/E13
E07	PHASE_13C_RESULT.md、PHASE_13D_PROGRESS.md、evaluation/ground_truth/	人工规范与审批历史记录，解释时须区分版本
E08	reports/phase6/、reports/phase7/、backend/app/collectors/、backend/app/enrichment/	真实有限采集、富化和失败状态
E09	PHASE_14A_RESULT.md、docs/phase14a/（来源矩阵、live-validation、verification-summary、测试结果）	来源适配、候选及工程验证原始材料
E10	work/local_demo_runtime/dashboard-before.png	历史真实本地页面截图
E11	docs/phase14a/live-intelligence-example.json	脱敏真实 API 投影；三类对象及来源断言/候选/空值字段摘录
E12	outputs/final-accuracy-validation/FINAL_ACCURACY_VALIDATION_RESULT.md；evaluation-freeze-manifest.md；49-question-results.json/csv	最新完整实验的请求、评分输入、逐题结果及冻结配置
E13	outputs/phase14c25/PHASE_14C25_RESULT.md；final-source-freeze.json；failure-ledger.json	C25 历史完整实验、冻结源码及回退关系
E14	outputs/final-live-demo/FINAL_LIVE_DEMO_RESULT.md；live-C08.json；live-C09.json；actual-wire.jsonl；live-evidence-reference-matrix.csv	演示案例原始请求、响应、模型请求及证据定位矩阵
E15	outputs/final-evidence-quality-review/FINAL_EVIDENCE_QUALITY_REVIEW.md；minimal-production-change.patch；regression-results.md	来源归组规则增量及定向验证原件
E16	outputs/final-correctness-comparison/final-advantage-verdict/FINAL_ADVANTAGE_VERDICT.md；evidence-adjudication.csv	主要配对题的证据裁定与结论原件

编号	材料	支持内容
E17	outputs/final-correctness-comparison/final-human-adjudication/FINAL_HUMAN_ADJUDICATION.md；reviewer-provenance-audit.csv	真人评审声明、锁定指纹缺口和分歧裁定
E18	outputs/final-submission-package/FINAL_SUBMISSION_PACKAGE_CHECK.md；demo-steps.md；preparation-checks.json	本地后端读取、源码哈希、演示步骤与限制；非新业务复测
E19	outputs/phase14c25/backup-receipt.json；backups/restore-verification.json	源码/原始证据及数据库备份；历史真实恢复与数量核对
E20	outputs/final-accuracy-diff/FINAL_ACCURACY_DIFF.md；outputs/final-readiness/core-scenarios.json	字段差异、风险语义及缺上下文/冲突记录原件
E21	outputs/phase14c28/PHASE_14C28_RESULT.md；regression-results.json；process-launch-diagnostics.md	Worker 组合执行的原始日志、堆栈与环境材料

附录 B 核心源码阅读入口

核心实现可依次阅读任务需求与完整性校验、来源归组与声明核验、资产版本判断、统一验收和答案封存。7.5 节提供源码节选，表 12 提供函数位置。

复现业务流程需要同时保留源码、模型配置、来源快照和授权资产记录。历史材料按独立版本归档，每次新调查生成并消费自身产物。